Incident management and response Introduction and Methods

Joakim Kävrestad
Jönköping School of Engineering
joakim.kavrestad@ju.se

© Crown Copyright, The National Cyber Security Centre 2023. This information is licensed under the Open Government Licence v3.0. To view this licence, visit https://www.nationalarchives.gov.uk/doc/open-government-licence/version/3/.

When you use this information under the Open Government Licence, you should include the following attribution: CyBOK memory analysis workshop slides © Crown Copyright, The National Cyber Security Centre 2023, licensed under the Open Government Licence: https://www.nationalarchives.gov.uk/doc/open-government-licence/version/3/.

Litterature note

- This lecture is based on the following CyBOK knowledge areas:
  - Security Operations and Incident Management

- Additional material is cited throughout the lecture

Agenda

- Security operations and incident management (SOIM) at a glance
- Incidents?!
- Handling the incidents!

SOIM

CyBOK

- Security Operations and Incident Response (SOIM)
  - Assumes that we can't, or won’t fully protect our cyber environment
  - Consequently, we acknowledge that there will be incidents
  - SOIM can be described as the processes and capabilities for handling that reality

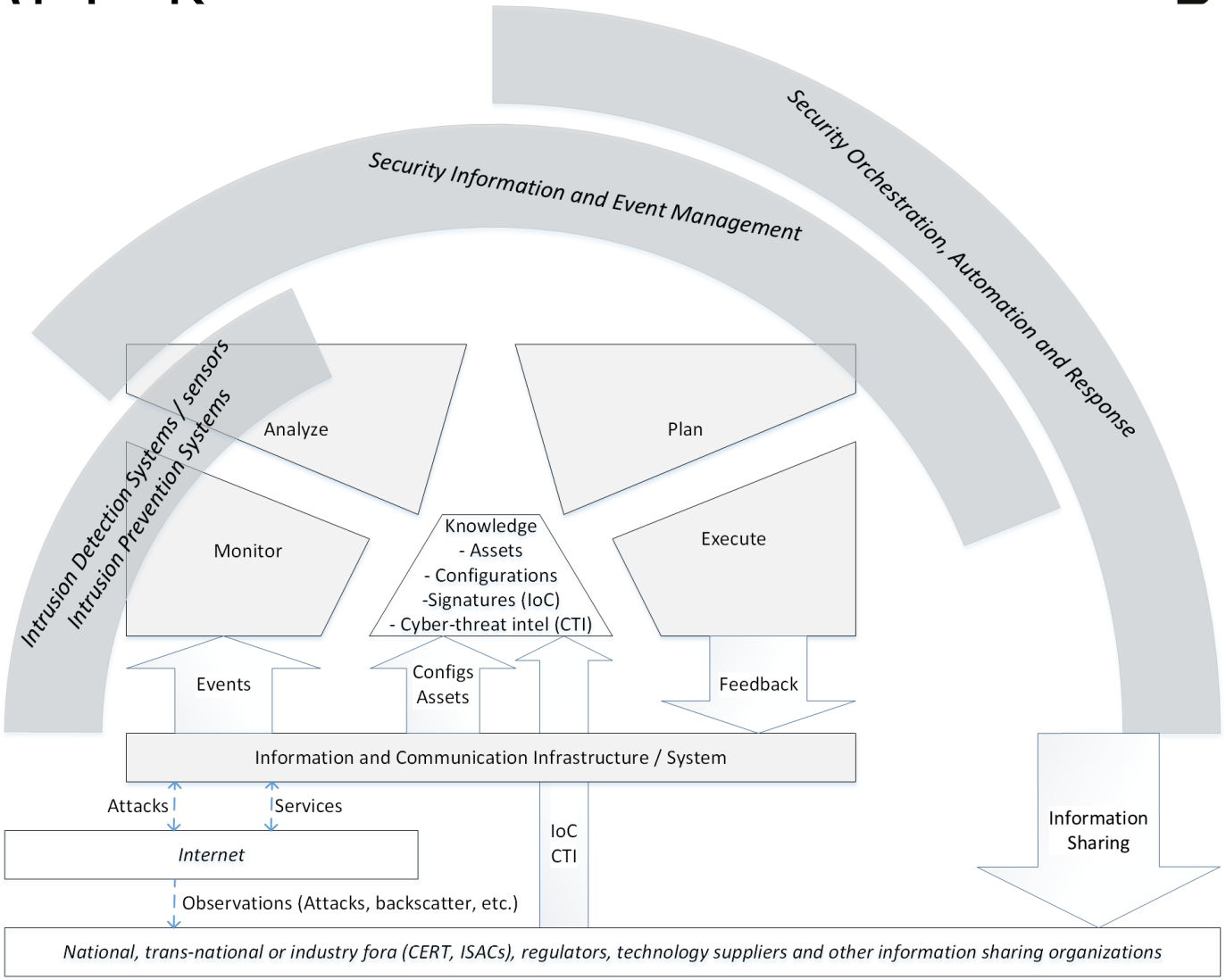
- Why don’t we want to be fully secure?
  - Security vs Usability
  - Financial reasons
  - Also, we can't

SOIM – MAPE-K

- SOIM can be seen as an application of the MAPE-K model for cybersecurity
  - Monitor, Analyze, Plan, Execute – Knowledge (MAPE-K)

- MAPE-K is an architecture for adaptive systems
  - An event-driven loop
  - Events, or the result of events, provide feedback to the system
  - Feedback is used to change the system behavior

SOIM – MAPF-K


Security Orchestration, Automation and Response
Security Information and Event Management
Intrusion Detection Systems / sensors
Intrusion Prevention Systems
Analyze
Plan
Monitor
Knowledge
- Assets
- Configurations
-Signatures (IoC)
- Cyber-threat intel (CTI)
Execute
Events
Configs
Assets
Feedback
Information and Communication Infrastructure / System
Attacks
Services
Internet
IoC
CTI
Information
Sharing
Observations (Attacks, backscatter, etc.)
National, trans-national or industry fora (CERT, ISACs), regulators, technology suppliers and other information sharing organizations

REFLECT!

- Use one minute to write down one-liners which describe what you just learned – come up with as many as you can.
- Join up in pairs or groups and compare your lists for another minute.
- Questions so far?

SOIM – MAPE-K

- SOIM workflows
  - Intrusion detection and prevention systems (IDPS)
  - Security Information and Event Management (SIEM)
  - Security Orchestration, Automation, and Response (SOAR)

- MAPE-K components
  - Monitor (IDPS)
  - Analyze (IDPS and SIEM)
  - Plan (SIEM and SOAR)
  - Execute (SOAR)

SOIM – The K

CyBOK

- SOIM requires knowledge and updates knowledge

- Several sources
  - Threat intel
  - Assets
  - Staff
  - ….

- Event-driven so that events are taken trough the loop and then generates new knowledge to the loop

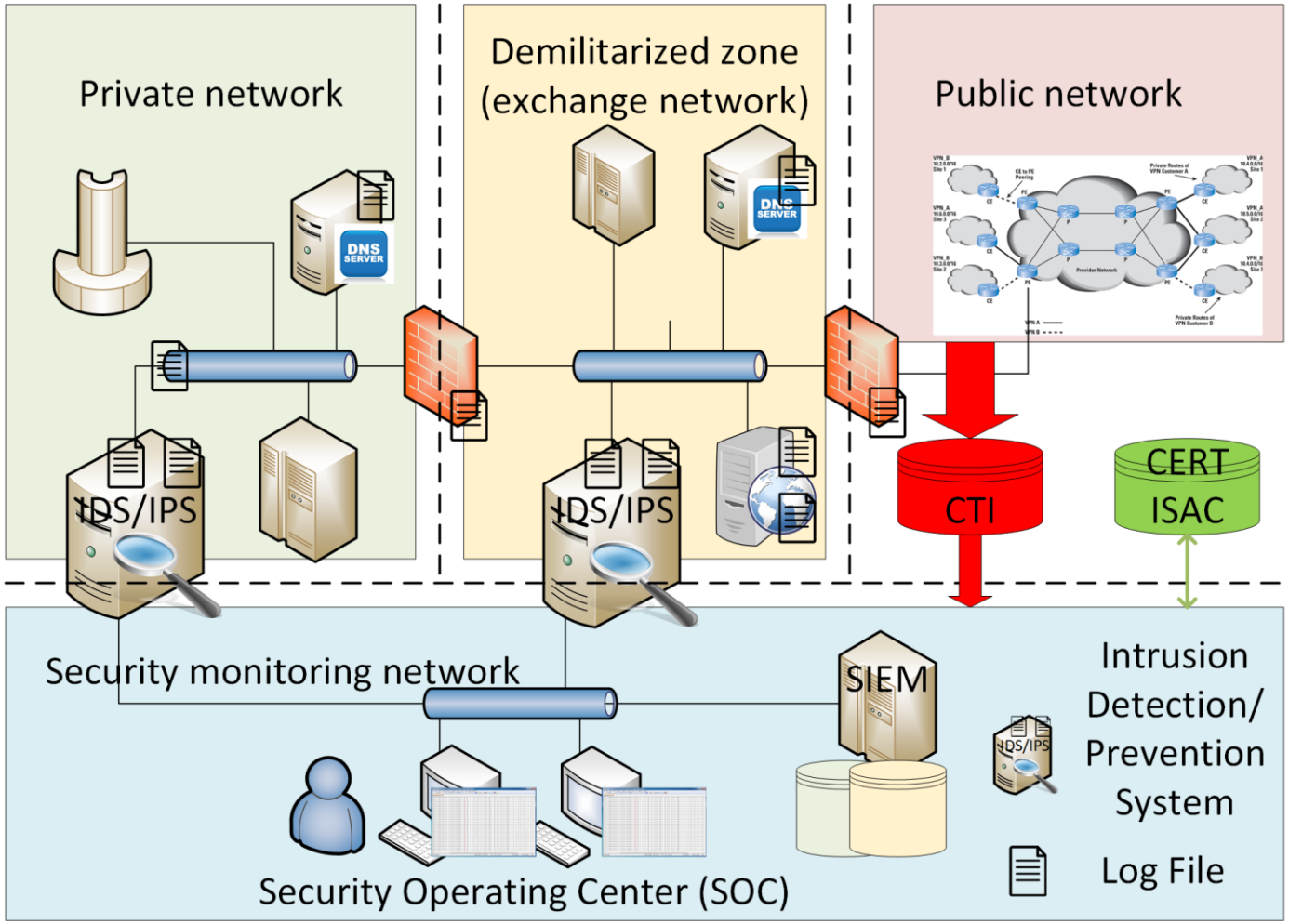
REFLECT!

- Use one minute to write down one-liners which describe what you just learned – come up with as many as you can.
- Join up in pairs or groups and compare your lists for another minute.
- Questions so far?

SOIM – Architectural principles

- SOIM assumes that there is some system that needs protection
- SOIM tools and processes are deployed in that system
- It is common practice to segment the system, for instance using DMZ and private networks

SOIM – Architectural principles



SOIM – Knowledge

CyBOK

- Knowledge mainly refers to intelligence and analytics
  - CTI – Cyber threat intelligence
  - ISAC – Information Sharing and Analysis Centers

- CTI
  - Detailed knowledge of threats against an organization

- ISAC
  - Organizations that gather data on cyber threats

SOIM – Knowledge management

- Maintaining an internal knowledge base is crucial for the ability to cross-reference system events with known intel

- Many open and commercial databases are available
  - CVE
  - Mitre ATT&CK
  - ….

SOIM – Honeypots

CyBOK

- A system or set of systems offered as bait to attackers
- Purpose is to present decoy machines that attackers will attack and monitor what happens
  - Learn about attacker techniques
  - Learn who the attackers are
- A way to gather own intel

SOIM – CTI

- Information and signature sharing
  - Sharing intel and signatures for different platforms
  - Malware Information Sharing Platform
  - SNORT rule sets
  - YARA signature exchange

- Indicators of Compromise (IoC)
  - Indicators of incidents, broadly speaking
  - Several standards for sharing

SOIM – Situational awareness

CyBOK

- *Awareness of any kind of suspicious or interesting activity taking place in cyberspace*
- Cyber threats are evolving and ever-changing
- Adaption to current trends helps defense
- Includes reports from official bodies such as ENISA, the European agency for cyber security

REFLECT!

- Use one minute to write down one-liners which describe what you just learned – come up with as many as you can.
- Join up in pairs or groups and compare your lists for another minute.
- Questions so far?

Incident handling

- Security operations
  - Avoiding bad events as far as possible (feasible)
  - Detecting bad events when they occur
  - Handling them when they occur

- Incident = bad/unwanted/abnormal event

- A response process is initiated on suspicion of an incident

Incident Response

CyBOK

- We now operate with an assume compromise set of mind
  - Incidents will happen
  - We just dont know when
- When an incident occurs, we need to minimize its impact by following an incident response plan
- Incident response is basically about managing incidents and includes the practices of responding to identified incidents

Incident Response – why?

CyBOK

- We know about the threat landscape by now
  - Script kiddies
  - Malware on the loose
  - Hacktivists
  - Pranksters
  - Organized crime
  - APT/state sponsored actors

- Staying safe is not a choice for many organizations, it’s a requirement

Incident Response – why?

CyBOK

- Being targeted by an attacker can lead to extreme losses for an organization
  - Leaks
  - Ransomware
  - …..
- Being able to respond to an incident in a proper way is a core business function
  - MAERSK(Not-Petya) vs Voice integrate (1177)
  - Impressed the IT world vs complete loss of trust and loss of business

Incident Response – how?

CyBOK

- Roughly divided into two tasks:
  - Establishing capabilities
  - Incident handling

- Litterature
  - CyBOK
  - Incident handler's handbook (SANS)
  - Guide to integrating forensic techniques into incident response. NIST Spec Publ 10:800–886

Incident Response – Establishing capabilities

- The task of getting ready

- An incident is a stressful situation
  - Loss of production
  - Media attention
  - Legal actions

- Being well prepared makes you know how to act and what to do

- Note that we should consider incidents as something that WILL happen rather than something that can happen

Incident Response – Establishing capabilities

- Create a Computer Security Incident Response Team (CSIRT)
  - Technical staff
  - Legal expertice
  - Public relations
  - HR
- Develop policies and procedures that describe what to do and how, and who
- Ensure access to relevant resources
- Training, training, training

Incident Response – Establishing capabilities

- The policy should outline the rules for incident response work

- Content to include:
  - What an incident is
    - Incident classification and how various incidents should be handled
  - CSIRT contact list
    - Members and their contact info
  - Contingency plan
    - Prioritization
  - Communication plan
    - Who to talk to and when
  - Resources that the CSIRT can use and allocate

Incident Response – Establishing capabilities

- Resources need to be easily available and can include
  - The policy
  - Important tools (more is more in this case)
  - Backup internet connection
  - Backup and recovery plans
  - Empty removable storage
  - Backup power
  - Backup peripherals
  - Backup laptop with tools
  - Evidence gathering gear

Incident Response – Handling

- Analysis
- Mitigation
- Communication

Incident Response – Handling - Analysis

- Investigate the incident
  - Type
  - Scope

- This is a difficult task that aims to understand the nature of the incident and the (potential) damage caused

Incident Response – Handling - Mitigation

- Focus on containing the incident
  - Isolate infected hosts
  - Isolate hosts critical to the organization

- Actual task depends on the nature of the incident
  - Cutting the network
  - Applying security patches
  - Reinstalling machines
  - Shutting down services
  - …

- Analysis and mitigation are often iterative phases

Incident Response – Handling - Communication

- Communication is important for several reasons
  - Legal and compliance
  - Warn others
  - Maintain trust, both internally and externally

- NOTE! As a community, we need to create a climate where we can talk and share. We need to stop shaming attack-victims!

Incident Response – Post

- Return to normal operation
  - Purge the incident from the system

- Post-incident activities
  - Measure the performance of the incident handling and learn from that
  - Legal aftermath
  - Communication
  - Possible long-term business impacts

REFLECT!

- Use one minute to write down one-liners which describe what you just learned – come up with as many as you can.
- Join up in pairs or groups and compare your lists for another minute.
- Questions so far?

Thank you for today!